

# BioSpecInfo

## Security, Privacy & Compliance — BioSpecInfo

---

Samuele Pio Provenzano

Versione **bsi-v174** · commit `de935fb`

Generato il 2026-09-25

Documento generato automaticamente dal sorgente Markdown versionato nel repository. La versione e il commit stampati in ogni piè di pagina identificano esattamente lo stato del software descritto.

# Security, Privacy & Compliance — BioSpecInfo

| Campo    | Valore                        |
|----------|-------------------------------|
| Software | BioSpecInfo                   |
| Autore   | Samuele Pio Provenzano        |
| Modello  | Client-side / Local-First PWA |

## 1. Privacy & protezione dei dati (GDPR)

### 1.1 Local-First per progettazione

- **Nessun account, nessun login, nessun tracciamento pubblicitario.**
- Tutti i dati dell'utente (molecole disegnate, preferenze, cronologia dei quiz, progressi di studio) sono conservati **esclusivamente in locale** sul dispositivo ( `localStorage` / `IndexedDB` / `sql.js` ), senza trasmissione a server dell'autore.
- **Non esiste un backend applicativo** che raccolga o elabori dati personali.

### 1.2 Trattamento dei dati e allineamento GDPR

- **Minimizzazione dei dati:** l'app non richiede dati personali per funzionare.
- **Assenza di trasferimento a terzi dell'autore:** i dati non lasciano il dispositivo per infrastrutture controllate dall'autore.
- **Chiamate esterne opzionali e trasparenti:** solo su azione dell'utente (ricerca di una molecola, apertura di un modello 3D) l'app interpella API pubbliche di terzi (PubChem, NASA/ESA, database spettrali). Tali richieste contengono **solo l'identificativo chimico** (es. SMILES/nome) e **nessun dato personale**. L'uso di questi servizi è soggetto alle rispettive privacy policy.
- **Diritto all'oblio locale:** l'utente può cancellare i dati svuotando lo storage del sito dal browser.

**Nota.** Questo allineamento descrive le proprietà di design local-first che favoriscono la conformità GDPR. Non costituisce una certificazione legale; per contesti regolamentati si raccomanda una valutazione DPIA dedicata.

## 2. Sicurezza applicativa (OWASP)

---

### 2.1 Superficie di attacco

Essendo un'applicazione **statica senza backend**, sono assenti per costruzione intere classi di vulnerabilità server-side (SQL injection su DB server, RCE lato server, autenticazione/sessione server, IDOR su API proprietarie).

### 2.2 Sanitizzazione degli input

- Il parsing di stringhe **SMILES / SMARTS** e di file molecolari è delegato a

**RDKit MinimalLib (WASM)**, che valida le strutture e rifiuta input malformati restituendo molecole non valide anziché eseguirli.

- Le stringhe provenienti da input o da API esterne, quando inserite nel DOM,

vanno trattate come non fidate. Il valore testuale (nomi, notazioni) è mostrato come contenuto testuale/ `textContent` o con escaping dei caratteri `&lt; >`.

### 2.3 Robustezza del runtime

- **Guardia su `localStorage`**: ogni accesso allo storage è protetto da

`try/catch` con fallback in memoria, per evitare che la modalità incognito o lo storage bloccato interrompa l'esecuzione (regressione storica risolta).

- **Degradazione controllata**: i pannelli non restano mai vuoti in silenzio; gli errori mostrano un messaggio e, dove applicabile, un pulsante "Riprova".

- **Isolamento delle sotto-app** in `iframe`.

### 2.4 Content Security Policy (raccomandazione di deploy)

Poiché l'app è pubblicabile su hosting statico, si raccomanda di servirla con header di sicurezza a livello di hosting/CDN:

- `Content-Security-Policy` restrittiva (`script/style self + WASM`), `frame-ancestors`,

`X-Content-Type-Options: nosniff`, `Referrer-Policy: no-referrer`.

- `Cross-Origin-Opener-Policy` / `Cross-Origin-Embedder-Policy` se in futuro si abiliteranno `SharedArrayBuffer` e i Web Worker paralleli (roadmap HPC).

---

## 3. Integrità e riproducibilità (allineamento GAMP 5)

---

Per l'uso in contesti farmaceutici/regolamentati, l'architettura è **compatibile** con i principi GAMP 5:

- **Determinismo**: i calcoli chemioinformatici (RDKit) sono deterministici e riproducibili a parità di input.

- **Tracciabilità delle versioni:** versionamento del codice su Git, cache del Service Worker versionata, changelog.
- **Trasparenza dei metodi:** i predittori euristici sono documentati con le loro fonti e i loro limiti (vedi *Validation Report*).

Anche qui: si tratta di **allineamento ai principi**, non di una qualifica formale (IQ/OQ/PQ), che richiederebbe un processo di validazione dedicato presso l'organizzazione utilizzatrice.

## 4. Riepilogo

| Aspetto                                       | Stato                             |
|-----------------------------------------------|-----------------------------------|
| Dati personali trasmessi a server dell'autore | <b>Nessuno</b>                    |
| Backend / database server                     | <b>Assente</b>                    |
| Validazione input molecolari                  | RDKit WASM                        |
| Escaping output nel DOM                       | Sì (contenuto non fidato)         |
| Guardia storage / degradazione errori         | Sì                                |
| CSP / header di sicurezza                     | Raccomandati a livello di hosting |
| Funzionamento offline                         | Sì (Service Worker)               |